

## INFORME TÉCNICO DE AUDITORÍA DE SEGURIDAD

Hallazgo: Falta de control de intentos en el endpoint de autenticación /login

### Control de versiones

Versión

1.0

Fecha

17/08/2025

Autor

Equipo de Seguridad -  
Blandskron SpA

## Resumen Ejecutivo

Durante la auditoría de seguridad se identificó una vulnerabilidad crítica en el endpoint /login de la aplicación web. La ausencia de controles frente a intentos de autenticación fallidos permite la ejecución de ataques de fuerza bruta que podrían derivar en accesos no autorizados. El presente informe detalla el hallazgo, la evidencia técnica, el impacto potencial y las recomendaciones para mitigar el riesgo.

## Detalle del Hallazgo Técnico

### Título del hallazgo

Falta de control de intentos en el endpoint de autenticación /login

### Resumen técnico

El endpoint de autenticación permite intentos ilimitados de login sin mecanismos de mitigación, lo que expone a la aplicación a ataques de fuerza bruta y compromete la seguridad de las credenciales.

### Evidencia técnica

Se realizaron múltiples intentos de autenticación fallidos contra el endpoint /login utilizando Burp Suite Intruder y scripts automatizados en Python. El servidor respondió con código HTTP 200 en cada intento, sin aplicar bloqueo ni CAPTCHA, confirmando la ausencia de medidas de protección.

### Impacto potencial

Un atacante puede automatizar el envío de múltiples combinaciones de usuario y contraseña hasta adivinar credenciales válidas. Esto puede derivar en accesos no autorizados, exposición de datos confidenciales y escalamiento de privilegios dentro del sistema.

### Recomendación técnica

Se recomienda implementar un mecanismo de limitación de intentos fallidos que bloquee temporalmente la cuenta o la IP. Incorporar un sistema CAPTCHA en el formulario de login, devolver códigos de error apropiados (ej. 401 Unauthorized) en lugar de HTTP 200, y habilitar monitoreo de intentos sospechosos.